

Exercise 1: Contrast network attacks and network hardening best practices.

1. Network Attack Types and Network Hardening Best Practices

FIC Bank operates in a high-risk financial environment that requires continuous protection. The organization handles highly sensitive financial data and depends on network connectivity to support both internal operations and remote users. From a network defender's perspective, NIST firewall guidance explains that effective network defense requires using appropriate firewall technologies along with clear security policies that control what traffic is allowed into and out of the network (Scarfone & Hoffman, 2009). Without proper network hardening controls in place, the network becomes vulnerable to different types of attacks. To reduce this risk, FIC Bank must implement strong security measures alongside a properly configured firewall. When these protections are not enforced, the bank is exposed to network attacks that can disrupt daily operations or compromise sensitive financial information.

One common network attack that poses a serious risk to FIC Bank is a man in the middle attack. This type of attack targets remote access connections used by employees working outside the organization. When a VPN is configured using weak or outdated authentication protocols, an attacker can position themselves between the remote user and the VPN server to intercept communication (Virgillito, 2014). During an active attack, user credentials may be captured while authentication is taking place. Once those credentials are obtained, attackers can impersonate legitimate users and gain unauthorized access to internal banking systems. This risk is especially concerning in a financial environment where remote access provides a direct path into sensitive systems. A best practice to reduce this threat is enforcing strong encryption and secure VPN authentication methods such as multi-factor authentication, which helps protect credentials and prevents intercepted traffic from being reused by attackers (Scarfone & Hoffman, 2009). In a financial environment, remote access protections are tested regularly because credential interception remains one of the most common intrusion paths.

Another network attack that poses a serious threat to FIC Bank is a distributed denial of service attack. DDoS attacks attempt to overwhelm systems with excessive traffic, causing services to slow down or become unavailable to legitimate users. For a financial institution, this type of attack can interrupt customer transactions and impact internal operations. End user devices often have fewer security protections in place, making laptops, tablets, and mobile phones easier targets for malware and credential harvesting. If these compromised devices connect to the network through a VPN, they can introduce malicious traffic directly into the corporate environment and contribute to a denial of service condition (Virgillito, 2014). To reduce this risk, FIC Bank should rely on firewall technologies that monitor traffic patterns and detect abnormal behavior. Properly configured firewalls, especially next-generation firewalls can filter unwanted traffic, limit unnecessary inbound connections, and prevent abnormal traffic flows from reaching critical systems (Scarfone & Hoffman, 2009). The firewall selected in Unit 3 supports these capabilities and helps protect network availability.

Another network attack that poses a risk to FIC Bank involves compromised or spoofed digital certificates used in SSL or TLS based VPN connections. Secure VPN access relies on trusted certificate authorities to confirm that a connection is legitimate. If a certificate authority is breached, attackers may obtain fraudulent digital certificates that appear valid to systems and users. This allows attackers to pose as secure connections and gather information about the corporate network, including open ports, protocols, or internal servers (Virgillito, 2014). In a financial environment, this type of attack can weaken trust in secure communications and expose sensitive systems. To reduce this risk, FIC Bank should enforce strict certificate validation and limit trust to approved certificate authorities. This control supports certificate trust policy enforcement, which is a core part of secure remote access governance. VPN functionality is often integrated into firewalls, allowing administrators to control and verify encrypted connections before granting access to internal resources (Scarfone & Hoffman, 2009). Proper firewall and VPN configuration helps ensure that only trusted connections are permitted to access the network.

A final network attack that presents a serious risk to FIC Bank is a zero-day exploit. Zero-day attacks target previously unknown vulnerabilities in systems or network software before vendors release patches or fixes. Because these vulnerabilities are not yet documented, traditional security controls may not immediately detect the attack. This creates a high risk for financial institutions, as attackers can bypass defenses and access sensitive systems without triggering obvious alerts. Zero day exploits are commonly used by advanced attackers who rely on stealth techniques to remain undetected while exploiting network weaknesses (SentinelOne, n.d.). While organizations cannot immediately patch unknown vulnerabilities, strong network monitoring and layered security controls help reduce the potential impact. Firewalls can limit exposure by restricting unnecessary traffic, enforcing strict access controls, and monitoring abnormal network behavior that may indicate exploitation attempts (Scarfone & Hoffman, 2009). While firewalls can not directly stop unknown vulnerabilities, they significantly reduce the exposure paths attackers depends on. By maintaining a properly configured firewall and continuously monitoring network activity, FIC Bank can improve its ability to detect suspicious behavior and limit damage caused by zero-day attacks.

Overall, FIC Bank faces multiple network attack types that threaten the confidentiality, integrity, and availability of its systems. While these attacks differ in technique, they all exploit weaknesses in network access, authentication, and traffic control. Man in the middle attacks take advantage of weak VPN authentication, distributed denial of service attacks overwhelm systems through excessive traffic, compromised digital certificates undermine trust in secure communications, and zero day exploits target unknown vulnerabilities before patches are available. The most effective best practice for countering these network attacks is deploying a next-generation firewall (NGFW) at the network perimeter as part of a layered defense strategy. NGFWs provide deep packet inspection, encrypted traffic visibility, application awareness, and centralized policy enforcement, which allows the organization to detect and control malicious activity even when traffic appears legitimate (Scarfone & Hoffman, 2009). When combined with strong VPN authentication, certificate validation, traffic monitoring, and network segmentation, this approach helps reduce the impact of both known and unknown threats. Implementing an

NGFW as the primary perimeter control allows FIC Bank to apply consistent security policies across remote access and internal traffic, making it an effective practice for defending against a wide range of network attacks in a high-risk financial environment. This contrast between attack behavior and hardening controls shows how firewall strategy must be driven by threat patterns, not just default configurations.

2. Differences between Windows Firewall and the Network Firewall

The Windows Firewall and the network firewall configured for FIC Bank serve different roles, even though both are designed to protect systems from unauthorized access. The Windows Firewall is a host based firewall that operates at the individual device level. It monitors and controls incoming and outgoing network traffic for a single computer based on predefined rules (Scarfone & Hoffman, 2009). This type of firewall provides an additional layer of protection by allowing only authorized traffic to reach the device while limiting outbound connections that could allow malware to spread. Windows Firewall can also enforce application based rules, meaning access decisions can be made based on which programs are allowed to communicate over the network. These capabilities make it effective for protecting remote or mobile user workstations and servers. However, its main limitation is that it focuses on a single host and lacks visibility into network wide traffic.

In contrast, the network firewall configured for FIC Bank operates at the network perimeter and protects multiple systems at once. It is responsible for inspecting traffic as it enters and leaves the organization's network. Unlike the Windows Firewall, the network firewall provides centralized control over security policies, allowing administrators to enforce consistent rules across all users, servers, and remote connections. Network firewalls are designed to monitor traffic patterns, inspect higher level protocols, and enforce access control policies across the enterprise environment (Scarfone & Hoffman, 2009). While the network firewall provides broad protection and visibility, it cannot fully prevent threats that originate from within the internal network. However, it is more effective at detecting and blocking large scale threats such as distributed denial of service attacks or unauthorized remote access attempts. Using both the Windows Firewall and the network firewall supports a layered security approach that strengthens overall network protection for FIC Bank.

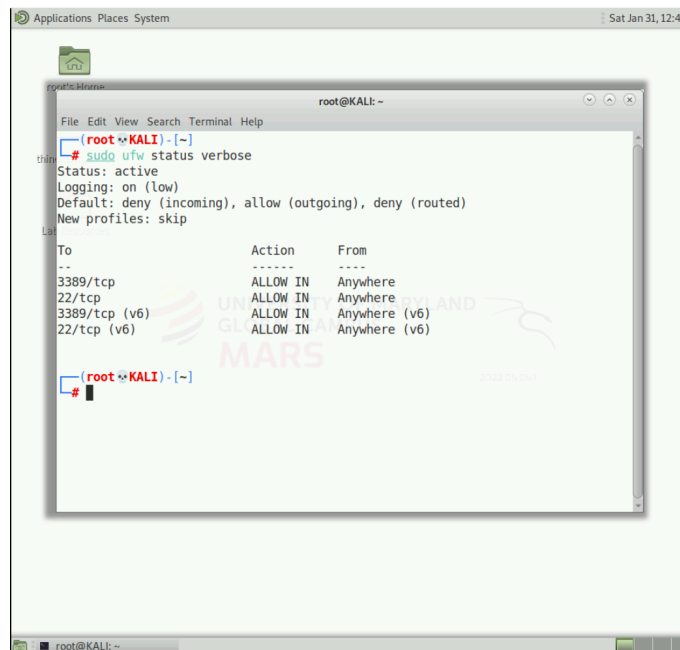
It is important to consider the limitations of each firewall when evaluating overall network security at FIC Bank. While the Windows Firewall provides detailed control at the individual device level, it cannot prevent threats from reaching the internal network before they interact with a host. Host based protections may be bypassed if a system is misconfigured or becomes compromised. Network firewalls have limitations when handling traffic they cannot fully inspect. Some network traffic is encrypted or tunneled in ways that prevent the firewall from seeing the contents of the data, which can allow certain threats to pass through undetected. Firewalls can only make decisions based on the traffic they are able to analyze, so security policies must clearly define how encrypted or unrecognized traffic is handled (Scarfone & Hoffman, 2009). These limitations show why relying on a single firewall is not sufficient and why layered security controls are necessary to protect both the network and individual systems.

These differences impact network security by reinforcing the need for defense in depth. The network firewall acts as the first line of defense by filtering and inspecting traffic before it reaches internal systems, while the Windows Firewall provides an additional layer of protection directly on individual devices. Layered security controls are necessary since no single firewall can protect against all threats (Scarfone & Hoffman, 2009). Together, they reduce the risk of unauthorized access, limit the spread of malware, and improve overall visibility into network activity. For FIC Bank, using both firewalls strengthens security by combining centralized network level protection with host level controls, ensuring that sensitive financial systems remain protected even if one layer is compromised. From an operational security standpoint, this layered firewall approach improves both prevention and detection capability.

Exercise 2: Modify network defense components to achieve hardening operational goals.

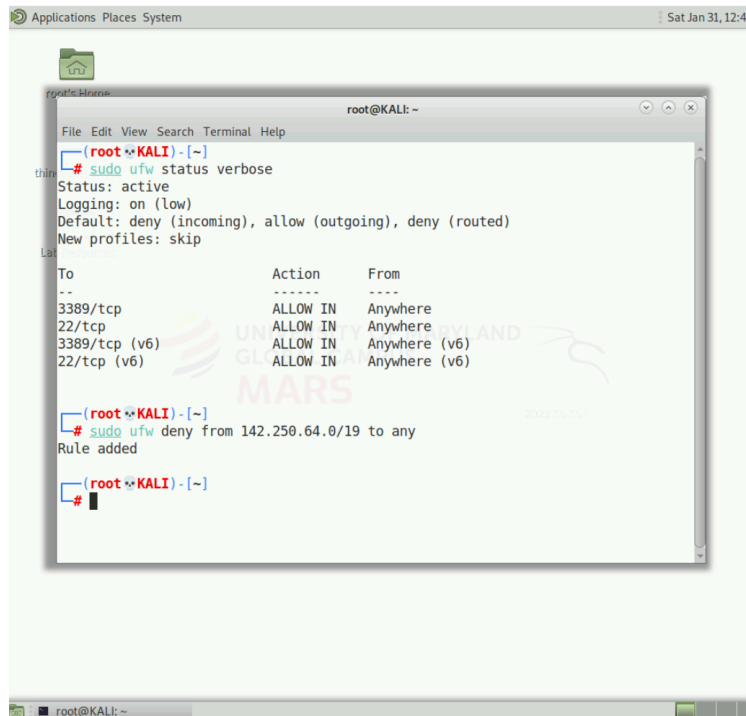
Check Current UFW Status:

Figure 1: UFW status before adding new firewall rules



```
root@KALI: ~  
File Edit View Search Terminal Help  
root@KALI: ~  
# sudo ufw status verbose  
Status: active  
Logging: on (low)  
Default: deny (incoming), allow (outgoing), deny (routed)  
New profiles: skip  
  
To Action From  
--  
3389/tcp ALLOW IN Anywhere  
22/tcp ALLOW IN Anywhere  
3389/tcp (v6) ALLOW IN Anywhere (v6)  
22/tcp (v6) ALLOW IN Anywhere (v6)  
  
root@KALI: ~  
#
```

Figure 2: Verification of UFW Firewall Rule Blocking Specific IP Traffic

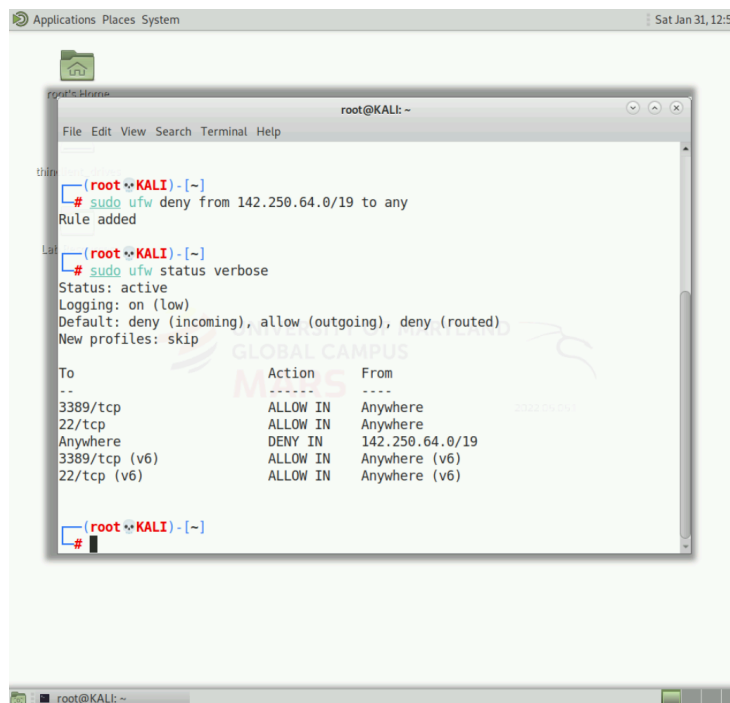


A terminal window titled 'root@KALI: ~' showing the output of the command 'sudo ufw status verbose'. The output indicates that UFW is active, logging is on (low), and the default policy is deny (incoming), allow (outgoing), deny (routed). The current rules are listed as follows:

To	Action	From
3389/tcp	ALLOW IN	Anywhere
22/tcp	ALLOW IN	Anywhere
3389/tcp (v6)	ALLOW IN	Anywhere (v6)
22/tcp (v6)	ALLOW IN	Anywhere (v6)

Below the table, the command 'sudo ufw deny from 142.250.64.0/19 to any' is entered, and the output shows 'Rule added'.

Figure 3: UFW Configuration After Blocking 142.250.64.0/19



A terminal window titled 'root@KALI: ~' showing the output of the command 'sudo ufw status verbose' after blocking the IP range 142.250.64.0/19. The output indicates that UFW is active, logging is on (low), and the default policy is deny (incoming), allow (outgoing), deny (routed). The current rules are listed as follows:

To	Action	From
3389/tcp	ALLOW IN	Anywhere
22/tcp	ALLOW IN	Anywhere
Anywhere	DENY IN	142.250.64.0/19
3389/tcp (v6)	ALLOW IN	Anywhere (v6)
22/tcp (v6)	ALLOW IN	Anywhere (v6)

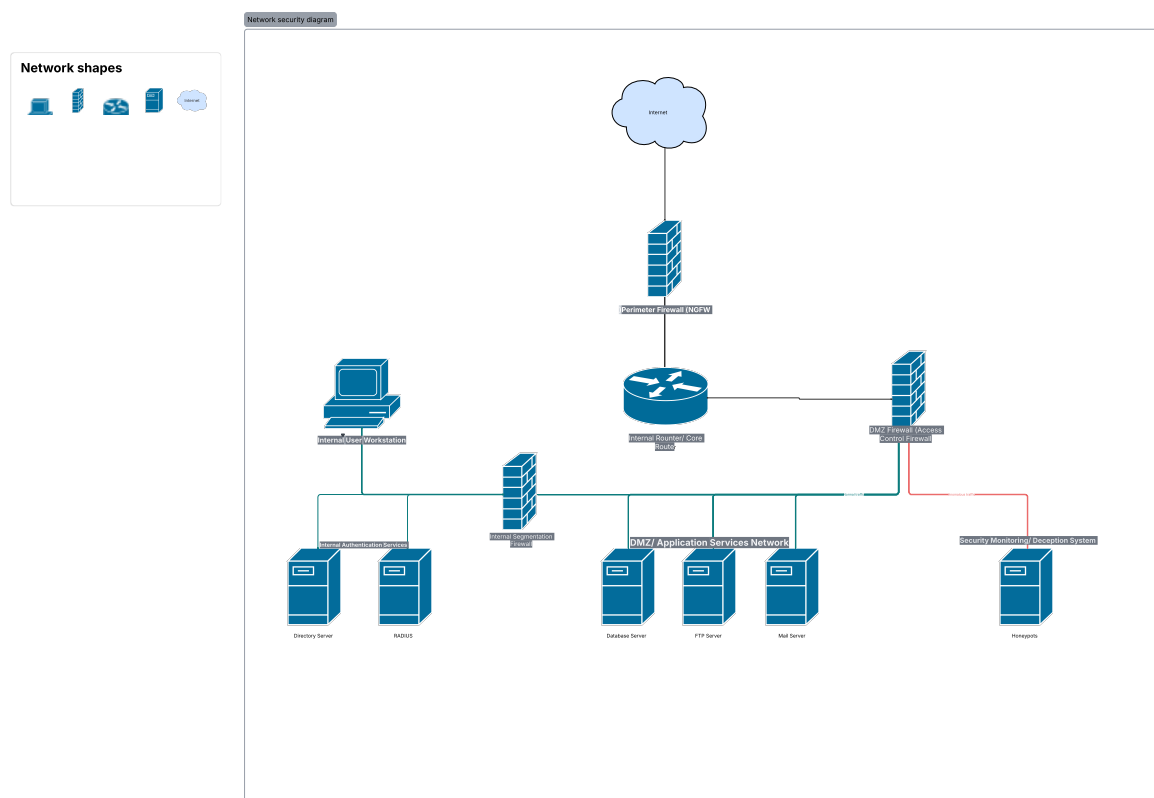
Below the table, the command 'sudo ufw deny from 142.250.64.0/19 to any' is entered, and the output shows 'Rule added'.

Firewall Configuration Considerations:

In this exercise, UFW was used to block incoming traffic from the Google IP range 142.250.64.0/19. While the rule was successfully applied and verified, blocking traffic based on a single IP range has clear limitations. Based on the UFW command output and rule verification screenshots, large service providers like Google use many IP ranges that change frequently, which means blocking one range may not fully restrict access to all related services. This shows that firewall configurations require careful planning to avoid unintended disruptions while still improving security.

This type of configuration may unintentionally block legitimate services that rely on shared infrastructure, which could affect normal network operations. In addition, IP-based blocking alone does not prevent tracking, data collection, or other network threats that occur through different methods. For FIC Bank, firewall rules must be carefully evaluated and supported by broader security controls such as monitoring, authentication policies, and network segmentation. These considerations highlight why firewall configurations should be tested and documented, and why they should be part of a layered security approach rather than a standalone solution. Operationally, this demonstrates why firewall hardening must be validated through testing and not just rule creation.

2. FIC Bank's network topology Lucidchart



3. Firewall Technology Analysis (Advantages & Disadvantages)

Different firewall technologies provide different levels of visibility and control across the FIC Bank network. The firewall shown in the network topology diagram represents an advanced firewall platform that includes packet filtering, stateful inspection, and application-level controls as part of its overall protection capabilities.

Packet filtering firewalls are one of the most basic types of firewalls. They operate at the network layer and make access control decisions based on packet details such as the packet's source IP address, the packet's destination address, the network protocol, transport-layer communication sessions, and the interface being traversed by the packet (Scarfone & Hoffman, 2009). One advantage is that packet filtering firewalls are fast and simple to configure within the network. One limitation is that they do not inspect the contents of traffic. If ports or services are allowed within the network, more advanced or disguised attacks may still pass through and attempt unauthorized access. Stateless packet filtering does not track connection state, which makes it more vulnerable to attacks that take advantage of weaknesses in TCP/IP behavior and protocol stacks (Scarfone & Hoffman, 2009). Stateful inspection improves this by tracking active sessions and only allowing packets that match known connections. This provides stronger protection than basic packet filtering, but visibility into application behavior is still limited. From a defensive operation standpoint, this limitation is why packet filtering alone is rarely sufficient in financial environments.

Application layer and proxy based firewalls provide deeper inspection than basic packet and stateful firewalls. They do not only focus on IP addresses and ports. Instead, these firewalls examine the actual content of network traffic at the application layer. An application proxy firewall operates at the application layer and inspects the actual content of the traffic (Scarfone & Hoffman, 2009). The proxy creates a separate connection to the internal system once the external system connects to the proxy. This prevents direct communication between outside hosts and internal systems, which helps hide internal IP addresses. It also allows the firewall to inspect commands, payload data, and protocol behavior before traffic is allowed through (Scarfone & Hoffman, 2009). Some proxy firewalls can decrypt and re-encrypt protected traffic for inspection and may require user authentication before allowing access.

The advantage of this firewall type is stronger visibility and tighter control over application behavior. This is helpful for web services and remote access connections. One disadvantage is that proxy and application layer firewalls require more processing and configuration, which can slow performance in high-traffic environments. For FIC Bank, security depth and performance needs must be balanced when selecting this technology. This tradeoff should be documented as part of firewall hardening decision criteria .

4. Most Suitable Firewall for FIC Bank and Justification

The most suitable firewall technology for FIC Bank secure remote access is a next-generation firewall placed at the network perimeter. Remote access paths create higher exposure risk before traffic reaches internal systems and should be closely inspected. These remote access paths

include VPN, RDP, and SSH connections, which are commonly used for administration and remote work. If these paths are not properly controlled, they can become direct entry points into sensitive banking systems. From a risk management perspective, perimeter inspection reduces remote access attack surface before internal exposure occurs.

In the designed topology, the firewall is positioned between the internet and the internal network, along with a DMZ segment used for systems that must be reachable from outside. DMZ zones are commonly used to host public-facing services while still forcing traffic through firewall controls and security policies (Scarfone & Hoffman, 2009). This design separates external-facing systems from core internal resources, which reduces risk if a public system is attacked. Traffic moving from the DMZ into the internal network still passes through firewall inspection and rule enforcement. This supports segmentation-based hardening goals required for layered defenses.

This placement allows remote access traffic to be filtered, inspected, and controlled before it interacts with protected banking resources. Instead of trusting traffic just because it uses an allowed port, the firewall examines how the connection behaves and what application activity is taking place. This approach supports secure remote access by enforcing centralized policies and deeper inspection at the main network entry point. The firewall can evaluate application behavior, user context, and session patterns instead of relying only on address and port rules. When combined with internal host firewalls and segmented network zones shown in the diagram, this creates layered protection across the network and reduces the chance that a single weakness or configuration error will expose sensitive financial systems. These modifications directly support network hardening operational goals through layered firewall control and segmentation.

Exercise 3: Assess testing output for indication of network access control effectiveness.

1. Wireshark Packet Capture Indicators of Firewall Blocking

The Wireshark packet captures before and after the firewall rule changes show a clear difference in TCP behavior that helps identify when traffic is being blocked versus when it is allowed. According to the Wireshark firewall troubleshooting example, a Python HTTP server was hosted on one virtual machine and another virtual machine attempted to access it as a client over HTTP on port 80 (OnCyberSec, n.d.). In the first test, the connection did not complete, which shows that inbound access was blocked by the firewall rule. With stateful inspection, a firewall tracks connection state and blocks traffic that does not match an expected valid session pattern (Scarfone & Hoffman, 2009). The capture shows multiple TCP SYN packets being sent from the client to the server, and those SYN packets were retransmitted several times. One important detail is that there were no SYN-ACK replies coming back from the server. When a connection is allowed, the server normally responds with SYN-ACK as part of the TCP three-way handshake process that is required to establish a reliable session (TCP ACK Overview, 2025). Since only SYN packets appear and no handshake sequence follows, this indicates that the inbound connection attempt was being blocked by the firewall rules.

The troubleshooting walkthrough demonstrated the firewall blocking behavior in a very visible way in the packet trace. The connection attempt was not permitted and the handshake was not completed, which indicates that only SYN packets appeared while the SYN-ACK and final ACK

steps never occurred. In a normal TCP connection, a successful session begins with a three-way handshake where the client sends SYN, the server responds with SYN-ACK, and the client returns ACK to confirm the session (TCP ACK Overview, 2025). That acknowledgment step is what confirms receipt and allows the session to move forward. Since the second step never appears in the capture, it shows that the request was being stopped before the session could be established. The repeated SYN retransmissions show that the client kept retrying the request and was not receiving acknowledgment approval to continue. This pattern is a strong indication that a filtering control, such as a firewall rule, is denying the traffic instead of allowing the connection to proceed. Firewall technologies that maintain state tables are specifically designed to only allow packets that match valid connection behavior and drop packets that do not meet those rules (Scarfone & Hoffman, 2009).

After the firewall rule was added to allow inbound HTTP traffic, the packet capture changed. The Wireshark trace indicated the full TCP three-way handshake pattern, including SYN from the client, SYN-ACK from the server, and ACK from the client. That sequence confirmed that the firewall was now allowing the connection to be established instead of blocking the traffic. In TCP communication, the SYN-ACK and final ACK steps are required to confirm receipt and successfully open a reliable session between hosts (TCP ACK Overview, 2025). The capture then continued with application traffic, including an HTTP GET request followed by an HTTP 200 OK response from the server, which indicates the request was processed successfully (OnCyberSec, n.d.). The successful status code and continued packet exchange demonstrate that the firewall rule adjustment worked as intended. This change in behavior aligns with firewall controls that allow packets matching approved rules and valid connection state to pass through inspection (Scarfone & Hoffman, 2009). The shift from repeated SYN attempts with no response to a completed handshake and valid HTTP response was the key packet-level indicator that firewall controls were effective and correctly enforced after the configuration change. This kind of packet trace evidence is commonly used during security testing to demonstrate that access control enforcement is working as designed.

2. Tests to Verify Firewall Capability and Expected Successful Outcomes

Firewall controls should be verified to ensure the network is properly safeguarded. Security teams validate this through repeatable connection and packet inspection test. To confirm the firewall is working as intended, I would perform direct connection tests and traffic inspection tests to identify whether unauthorized traffic is blocked and authorized traffic is allowed. Firewalls are designed to control which traffic is permitted based on defined policy and connection state, so testing should focus on both denied and approved connection attempts (Scarfone & Hoffman, 2009). It is important to confirm that firewall rules are working through actual network behavior and not just configuration settings, since a rule may look correct in the firewall console but still fail when real traffic is tested. To verify that the network safeguard is effective, I would perform a controlled port access test and a packet comparison test to confirm that the firewall rules are correctly applied and enforced.

The first test I would perform is a controlled port access test against a blocked service. To perform this test, I would try to connect to a server service on a port that is not allowed by the

firewall, such as attempting to reach an HTTP or SSH service from a client system when the inbound rule is not enabled. This type of test is similar to a basic port scan, where packets are sent to specific ports to observe how the system responds and whether protections like firewalls are actively filtering traffic (Fortinet Cyber Glossary, n.d.). The test can be done using a web browser, a curl command, or vulnerability scanning tools such as Nmap. Using multiple tools strengthens the reliability of the test. A successful firewall configuration would show that the connection attempt fails or times out instead of completing. From a packet capture view, the expected result would be repeated SYN packets without a completed SYN-ACK and ACK handshake sequence. In TCP communication, a connection is only established when the three-way handshake completes, which requires SYN, SYN-ACK, and ACK steps to confirm receipt and session setup (TCP ACK Overview, 2025). When those steps do not appear, it shows the session is being stopped before it is established, which matches expected firewall filtering behavior and indicates the rule is working correctly.

The second test I would perform is a packet capture comparison test before and after allowing a specific firewall rule. In this test, I would capture traffic in Wireshark while the firewall rule is blocking the service, then enable the correct firewall rule and repeat the same connection attempt. By comparing the results from both firewall rule, it will confirm whether the firewall is actually enforcing access control instead of only relying on configuration settings. When the firewall is correctly configured, the packet capture should clearly change between the two tests. Before the rule is added, the capture should show failed connection behavior, such as SYN retransmissions and no completed handshake sequence. After the rule is added, the capture should show a full TCP three-way handshake followed by normal application traffic, such as an HTTP request and a valid server response. This before-and-after comparison align with evidence-based testing practice recommended in firewall assessment guidance. A completed handshake confirms that the connection state was accepted and allowed to continue, which is required for reliable TCP communication (TCP ACK Overview, 2025).

Stateful firewalls are designed to allow packets that match an approved rule and valid connection state while dropping packets that do not match expected session behavior (Scarfone & Hoffman, 2009). A successful result in this test would show blocked handshake patterns before the rule and completed handshake plus application data after the rule, which demonstrates that the firewall is effectively protecting and controlling network access.

Overall, a firewall configuration can be considered successful when blocked services consistently fail to connect, allowed services complete the handshake and exchange data normally, and packet captures match the expected TCP patterns for both scenarios. When denial behavior and approval behavior are both visible and repeatable during testing, it confirms that the firewall is actively enforcing network access control instead of simply being present in the topology. This confirms the control is operationally effective, not just correctly configured on paper.

Exercise 4: Devise test procedures for network defense components.

1. Firewall Test Plan and Effectiveness Criteria

FIC Bank's security policies need to be evaluated and tested to confirm that the firewall is operating in compliance with those requirements. The testing should examine both the firewall configuration and its behavior under real network traffic conditions. To build a firewall test plan, the security assessment should include review techniques, ruleset checks, and technical testing methods so that controls are validated through observed behavior and supporting evidence, not just written documentation (Scarfone & Hoffman, 2008). This approach helps verify that the firewall is correctly enforcing access control, blocking unauthorized traffic, and allowing only approved services on the network. The test plan should include rules and policy review, port and service identification testing, log monitoring verification, network sniffing and packet capture validation, and remote access testing procedures.

The first part of the firewall test plan would be a ruleset and policy review. FIC Bank's written security policies focus on remote access, administrative access, and public-facing services, so the firewall rules should be reviewed and compared directly against what those policies require. This helps confirm that the rules are not only present, but enforcing what the policy expects in real network activity. Ruleset reviews are used to identify gaps, weaknesses, and unintended communication paths in firewall rules and access control lists (Scarfone & Hoffman, 2008). The rules should follow least-privilege principles, meaning only the required ports, protocols, and approved source addresses are allowed, while all other traffic is denied by default. As part of this step, the review should cover network and host-based firewall rules, IDS/IPS rulesets, and router access control lists to make sure protection stays consistent across layered defenses and overall risk is reduced.

The next step in the firewall test plan would be port and service identification testing from both an external and internal viewpoint. This involves scanning across the firewall boundary using approved assessment tools to see which ports and services are actually reachable. The goal is to confirm that only expected and authorized services are visible, and that unnecessary services are not exposed. Network port and service identification is used to identify active hosts, open ports, and the services running on them so that potentially vulnerable services can be flagged for further review (Scarfone & Hoffman, 2008). Only approved services such as remote access gateways and authorized administrative services should be reachable through the firewall. If unexpected ports or services respond during testing, that would indicate the firewall rules are too broad or not fully aligned with security policy. This type of testing helps confirm that the firewall is correctly limiting network exposure and not allowing unintended entry points into protected systems (Scarfone & Hoffman, 2008).

Another important part of the firewall test plan is log and monitoring verification. Firewall logging should be reviewed to confirm that both allowed and denied connection attempts are being recorded correctly. Log review is used to check whether security controls are capturing the right security events and whether the organization is following its logging practices during real activity (Scarfone & Hoffman, 2008). As part of this test, I would generate both approved and blocked connection attempts. After that is completed, I would verify that each event appears in

the firewall logs with details such as source address, destination, port, action taken, and timestamp. This helps reveal misconfigurations or repeated unauthorized access attempts that might otherwise be missed. It also makes it easier to quickly confirm whether configuration settings are working as intended. If traffic is blocked but no log record is created, that limits visibility for incident response and weakens the firewall's effectiveness as a security control. Reviewing the logs helps confirm that the firewall is not only filtering traffic, but also providing usable audit evidence to support monitoring and investigation activities.

Another step in the firewall test plan should include network sniffing and packet capture validation using a tool such as Wireshark. Network sniffing is a passive testing method that observes network communications and protocol behavior without actively interfering with traffic (Scarfone & Hoffman, 2008). In this step, packet captures are reviewed to further confirm that firewall filtering is working at the traffic level and not just appearing correct based on the firewall configuration alone. By capturing traffic behind the firewall and reviewing connection attempts, it becomes easier to see which services are being blocked and which services are being allowed. Blocked services should show failed connection behavior, while approved services should successfully complete their connection process. For example, denied traffic would typically show incomplete TCP handshakes or repeated SYN attempts, while approved traffic would show a completed handshake and normal application exchanges. This process helps detect unexpected protocols or unauthorized traffic patterns that might not be noticed through ruleset review alone (Scarfone & Hoffman, 2008). This type of validation provides real evidence that firewall rules are being enforced during live network activity and not just defined on paper.

The final step in the firewall test plan is secure remote administration testing, which focuses on how remote access is actually controlled and protected during real use. Remote access testing is used to find weak entry points and check whether there are any alternate paths into the network that could bypass perimeter defenses (Scarfone & Hoffman, 2008). This includes access methods such as VPN connections, SSH tunnels, and remote desktop services, so each one should be reviewed and tested directly. The remote access rules should be checked carefully to make sure there are no unintended access paths or rule misconfigurations that could allow unauthorized entry (Scarfone & Hoffman, 2008). Each approved remote access method should be tested by attempting a connection and confirming that authentication is required before access is granted. This shows the control is working in real activity, not just set correctly in the firewall settings. Testing each approved remote access method by attempting a connection and confirming authentication helps verify that access requirements are being enforced. I would test invalid credentials and denied accounts to confirm that access is rejected and logged. Access should only work when the correct authentication method is used and the connection follows policy. Any remote access service that allows entry without approval or required authentication would be considered a failed control. These tests should be done during low-usage periods so normal operations are not disrupted while still confirming that remote access protections are enforced correctly (Scarfone & Hoffman, 2008).

A firewall at FIC Bank would be considered effective if it consistently shows that security rules are being enforced in real network activity, not just in configuration settings. It should follow least-privilege principles, only expose approved services, and block unauthorized ports,

protocols, and connection attempts. It should correctly log both allowed and denied traffic, so security teams have usable audit records. Remote access paths should always require proper authentication and should fail when incorrect credentials are used. Packet captures and testing results should repeatedly show that unauthorized connections are stopped and approved connections complete successfully. Security assessments should confirm controls are operating correctly in the real environment, not only documented on paper (Scarfone & Hoffman, 2008). When repeated tests produce consistent and expected results across ruleset review, scanning, logging, packet capture, and remote access testing, the firewall can be considered effective in its role.

2. Firewall Configuration Steps Based on Security Policy Requirements

It is critical that FIC Bank properly configure a firewall to maintain the security of the network. Typically, it starts with a written security policy to ensure that the firewall has enforced rules at a network level. This first approach is to translate policy requirements into specific firewall rules and controls. FIC Bank must identify what traffic should be allowed, what must be restricted, and which services require stronger protection, such as remote access and administrative functions. Firewall and rules controls should be reviewed and aligned with policy so that security control be implemented in system configurations (Scarfone & Hoffman, 2008).

The first step in configuring the firewall is to identify what traffic should be allowed based on the organization's security policy. To determine allowed traffic, the organization should review approved services, user access requirements, remote administration methods, and public-facing systems. This step should be completed before creating any firewall rules, so that the configuration is based on defined security expectations instead of assumptions. Firewall and security configuration settings should be examined against organizational policy to confirm they are correctly implemented and not introducing unintended exposure (Scarfone & Hoffman, 2008). Each approved service should be matched to its required ports, protocols, and source locations. This helps ensure the firewall rules are created based on actual organizational needs and not overly broad permissions.

The next step is to configure the firewall using a deny-by-default approach. This approach blocks all inbound and outbound traffic unless it is specifically permitted by firewall policy (NIST, n.d). This reduces the risk of exposure and supports least-privilege access at the network boundary. Each rule should be created for a specific purpose, such as allowing secure web traffic or approved remote administration, while unused or insecure services remain blocked. Ruleset and security configuration reviews are used to identify deviations from organizational security policy and system security flaws, including overly broad permissions and unnecessary open services (Scarfone & Hoffman, 2008). Firewall configuration should be driven by policy and verified through ruleset and security configuration review practices. This includes reviewing each firewall rule and carefully validating the allowed ports, protocols, destinations, and source addresses. Taking this approach helps reduce the attack surface and makes it easier to trace every firewall rule back to an approved operational need.

After the policy requirements and deny-by-default approach are defined, the next step is to create and organize specific firewall rules in a clear and structured order. Each rule should be written as

specific as possible, using specific IP ranges, ports, and protocols. This reduces the chance of accidental exposure and makes each rule easier to justify. More specific rules should be prioritized before general rules. This approach helps ensure traffic is evaluated correctly and most specific rule is matched first. Each firewall rule should be clearly labeled with its purpose and business needs, so administrators can understand why it exists and when it should be reviewed or removed. Firewall and security configuration settings should be examined against organizational policy to confirm they are correctly implemented and not introducing unintended exposure (Scarfone & Hoffman, 2008). Writing rules with specific scope, clear order, and documented purpose improves long-term maintainability and lowers the risk of configuration mistakes that could weaken perimeter defenses.

Another important step when configuring the firewall is enabling logging and monitoring settings from the beginning of the configuration. The firewall should be configured to record the allowed and denied traffic, especially for sensitive systems, administrative access attempts, and remote connections. These logs should capture details such as source and destination addresses, ports, timestamps, and the action taken by the firewall. Reviewing logs helps validate that systems are operating according to established policy and can expose misconfigured controls and unauthorized access attempts (Scarfone & Hoffman, 2008). By enabling logging during the initial configuration phase with help detect rule errors, suspicious behavior, and repeated blocked attempts. Without proper logging enabled, the firewall may still filter traffic, but security teams would have limited visibility into what actually occurred and how the control performed.

The next step in firewall configuration is to handle remote access as a separate and higher-risk category when setting up firewall rules. Only approved remote access technologies such as VPN connections, SSH, and remote desktop services should be permitted, and each should have its own restricted rule instead of being grouped into broad access permissions. Firewall settings will ensure there are no unintended remote access paths or hidden services that will allow someone to enter the network without authorization. Remote access methods should be reviewed for vulnerabilities and misconfigurations because they can create alternate entry points that bypass perimeter defenses if not properly controlled (Scarfone & Hoffman, 2008). Authentication should always be required for remote access connections, and firewall rules should be limited to known source networks. Configuring remote access this way helps ensure that external administration paths stay protected and aligned with security policy instead of becoming accidental backdoors.

Once the firewall rules are created, the configuration should be clearly documented and reviewed. Each firewall rule should be connected to a specific policy requirement or business need. Understanding why each rule exists helps justify and support it. Writing this information down and keeping track of it helps with future audits, troubleshooting, and rule cleanup. It makes it easier for other administrators to review the firewall settings without guessing the purpose of each rule. Good documentation reduces configuration mistakes and helps keep security controls consistent over time. Firewall configuration should be treated as an ongoing process instead of a one-time setup. Rules should be reviewed on a regular schedule, outdated or unused rules should be removed, and any new access needs should go through a formal change process before being added. As systems, users, and threats change, firewall rules should be adjusted to stay aligned with current security policy. Regular review and maintenance help

ensure the firewall continues to properly screen and block unwanted traffic while still supporting normal business operations.

References:

- SentinelOne. (2025, October 7). *Top 14 network security risks impacting businesses today*. SentinelOne. <https://www.sentinelone.com/cybersecurity-101/cybersecurity/network-security-risks/>
- Virgillito, D. (2014, September 30). *The importance of an effective VPN remote access policy*. Infosecinstitute. <https://www.infosecinstitute.com/resources/general-security/importance-effective-vpn-remote-access-policy/>
- Scarfone, K., Hoffman, P., National Institute of Standards and Technology, & Virtual Private Network Consortium. (2009d). Guidelines on firewalls and firewall policy. In *NIST Special Publication 800-41* (p. 48) [Report]. National Institute of Standards and Technology. <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-41r1.pdf>
- JumpCloud. (2025, August 4). What is ACK (Acknowledge)? TCP Flag Definition & Function - JumpCloud. <https://jumpcloud.com/it-index/what-is-ack-acknowledge>
- *What is a port scan? How to prevent port scan attacks?* | Fortinet. (n.d.). Fortinet. <https://www.fortinet.com/resources/cyberglossary/what-is-port-scan>
- CSRC Content Editor. (n.d.). *Deny by default - Glossary* | CSRC. https://csrc.nist.gov/glossary/term/deny_by_default